Online shop

Example model for ThreatSketch: a customer orders from a web shop that stores orders and charges cards.

Owner
ThreatSketch example

Created
13 October 2026, 17:37

Template
SDL TM Knowledge Base (Core)

Diagrams
1

Review before sharing

- 34 of 38 threats are still Not Started. Triage each one as Mitigated, Not Applicable or Needs Investigation.

Threat Model Summary

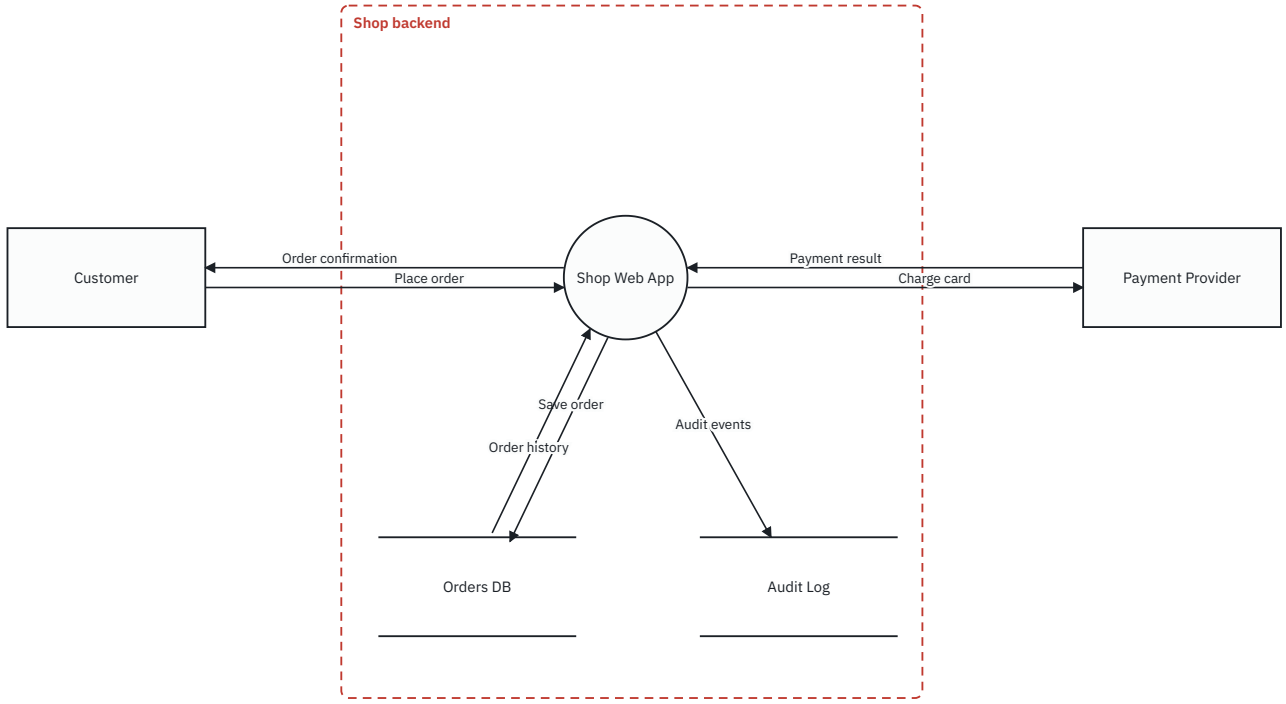
38	34	1	1	2
Total	Not Started	Needs Investigation	Not Applicable	Mitigation Implemented



Not Started 34 Needs Investigation 1 Not Applicable 1 Mitigated 2

Category	Threats	Open
Spoofing	6	5
Tampering	6	5
Repudiation	8	8
Information Disclosure	2	2
Denial Of Service	8	7
Elevation Of Privilege	8	8

Diagram: Online shop



Online shop: 5 elements, 7 data flows, 1 trust boundary

Threats 38 Not Started 34 Needs Investigation 1 Not Applicable 1 Mitigated 2

Interaction: Place order

Customer → Shop Web App · crosses **Shop backend**

1 **Spoofing the Customer External Entity** ● Mitigated

Category Spoofing Priority High Generated by SDL rule S3

Customer may be spoofed by an attacker and this may lead to unauthorized access to Shop Web App. Consider using a standard authentication mechanism to identify the external entity.

Justification
Customers sign in with a password and a one-time code.

2 **Cross Site Scripting** ● Mitigated

Category Tampering Priority High Generated by SDL rule T13.1

The web server 'Shop Web App' could be a subject to a cross-site scripting attack because it does not sanitize untrusted input.

Justification
All output is encoded by the template engine; a CSP blocks inline scripts.

3 **Potential Data Repudiation by Shop Web App** ● Needs Investigation

Category Repudiation Priority Medium Generated by SDL rule R6

Shop Web App claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification
Check whether order changes are logged with the user ID.

4 **Potential Process Crash or Stop for Shop Web App** ● Not Applicable

Category Denial Of Service Priority Low Generated by SDL rule D3

Shop Web App crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification
The web app runs behind a load balancer with health checks.

5 **Data Flow Place order Is Potentially Interrupted** ○ Not Started

Category Denial Of Service Priority High Generated by SDL rule D4

An external agent interrupts data flowing across a trust boundary in either direction.

Justification <no mitigation provided>

6 **Elevation Using Impersonation** ○ Not Started

Category Elevation Of Privilege Priority High Generated by SDL rule E5

Shop Web App may be able to impersonate the context of Customer in order to gain additional privilege.

Justification <no mitigation provided>

7 **Shop Web App May be Subject to Elevation of Privilege Using Remote Code Execution** ○ Not Started

Category Elevation Of Privilege Priority High Generated by SDL rule E6

Customer may be able to remotely execute code for Shop Web App.

Justification <no mitigation provided>

8 **Elevation by Changing the Execution Flow in Shop Web App** ○ Not Started

Category Elevation Of Privilege Priority High Generated by SDL rule E7

An attacker may pass data into Shop Web App in order to change the flow of program execution within Shop Web App to the attacker's choosing.

Justification <no mitigation provided>

9 **Cross Site Request Forgery** ○ Not Started

Category Elevation Of Privilege Priority High

Generated by SDL rule 8404dcf5-bdd8-4902-abc2-3b6c967b0261

Cross-site request forgery (CSRF or XSRF) is a type of attack in which an attacker forces a user's browser to make a forged request to a vulnerable site by exploiting an existing trust relationship between the browser and the vulnerable web site. In a simple scenario, a user is logged in to web site A using a cookie as a credential. The other browses to web site B. Web site B returns a page with a hidden form that posts to web site A. Since the browser will carry the user's cookie to web site A, web site B now can take any action on web site A, for example, adding an admin to an account. The attack can be used to exploit any requests that the browser automatically authenticates, e.g. by session cookie, integrated authentication, IP whitelisting. The attack can be carried out in many ways such as by luring the victim to a site under control of the attacker, getting the user to click a link in a phishing email, or hacking a reputable web site that the victim will visit. The issue can only be resolved on the server side by requiring that all authenticated state-changing requests include an additional piece of secret payload (canary or CSRF token) which is known only to the legitimate web site and the browser and which is protected in transit through SSL/TLS. See the Forgery Protection property on the flow stencil for a list of mitigations.

Justification <no mitigation provided>

Interaction: Order confirmation

Shop Web App → Customer · crosses **Shop backend**

10 **Spoofing of the Customer External Destination Entity** ○ Not Started

Category Spoofing Priority High Generated by SDL rule S8

Customer may be spoofed by an attacker and this may lead to data being sent to the attacker's target instead of Customer. Consider using a standard authentication mechanism to identify the external entity.

Justification <no mitigation provided>

11 **External Entity Customer Potentially Denies Receiving Data** ○ Not Started

Category Repudiation Priority High Generated by SDL rule R7

Customer claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification <no mitigation provided>

12 **Data Flow Order confirmation Is Potentially Interrupted** ○ Not Started

Category Denial Of Service Priority High Generated by SDL rule D4

An external agent interrupts data flowing across a trust boundary in either direction.

Justification <no mitigation provided>

Interaction: Save order

Shop Web App → Orders DB

13 **Spoofing of Destination Data Store Orders DB** — Not Started

Category Spoofing Priority High Generated by SDL rule S7.1

Orders DB may be spoofed by an attacker and this may lead to data being written to the attacker's target instead of Orders DB. Consider using a standard authentication mechanism to identify the destination data store.

Justification <no mitigation provided>

14 **Potential SQL Injection Vulnerability for Orders DB** — Not Started

Category Tampering Priority High Generated by SDL rule T7

SQL injection is an attack in which malicious code is inserted into strings that are later passed to an instance of SQL Server for parsing and execution. Any procedure that constructs SQL statements should be reviewed for injection vulnerabilities because SQL Server will execute all syntactically valid queries that it receives. Even parameterized data can be manipulated by a skilled and determined attacker.

Justification <no mitigation provided>

15 **Weak Credential Storage** — Not Started

Category Information Disclosure Priority High Generated by SDL rule I24

Credentials held at the server are often disclosed or tampered with and credentials stored on the client are often stolen. For server side, consider storing a salted hash of the credentials instead of storing the credentials themselves. If this is not possible due to business requirements, be sure to encrypt the credentials before storage, using an SDL-approved mechanism. For client side, if storing credentials is required, encrypt them and protect the data store in which they're stored

Justification <no mitigation provided>

16 **Potential Excessive Resource Consumption for Shop Web App or Orders DB** — Not Started

Category Denial Of Service Priority High Generated by SDL rule D2

Does Shop Web App or Orders DB take explicit steps to control resource consumption? Resource consumption attacks can be hard to deal with, and there are times that it makes sense to let the OS do the job. Be careful that your resource requests don't deadlock, and that they do timeout.

Justification <no mitigation provided>

Interaction: Order history

Orders DB → Shop Web App

17 **Spoofing of Source Data Store Orders DB** — Not Started

Category Spoofing Priority High Generated by SDL rule S7

Orders DB may be spoofed by an attacker and this may lead to incorrect data delivered to Shop Web App. Consider using a standard authentication mechanism to identify the source data store.

Justification <no mitigation provided>

18 **Cross Site Scripting** Not Started

Category Tampering Priority High Generated by SDL rule T13.1

The web server 'Shop Web App' could be a subject to a cross-site scripting attack because it does not sanitize untrusted input.

Justification <no mitigation provided>

19 **Persistent Cross Site Scripting** Not Started

Category Tampering Priority High Generated by SDL rule T13.2

The web server 'Shop Web App' could be a subject to a persistent cross-site scripting attack because it does not sanitize data store 'Orders DB' inputs and output.

Justification <no mitigation provided>

20 **Weak Access Control for a Resource** Not Started

Category Information Disclosure Priority High Generated by SDL rule I23

Improper data protection of Orders DB can allow an attacker to read information not intended for disclosure. Review authorization settings.

Justification <no mitigation provided>

Interaction: Charge card

Shop Web App → Payment Provider · crosses **Shop backend**

21 **Spoofing of the Payment Provider External Destination Entity** Not Started

Category Spoofing Priority High Generated by SDL rule S8

Payment Provider may be spoofed by an attacker and this may lead to data being sent to the attacker's target instead of Payment Provider. Consider using a standard authentication mechanism to identify the external entity.

Justification <no mitigation provided>

22 **External Entity Payment Provider Potentially Denies Receiving Data** Not Started

Category Repudiation Priority High Generated by SDL rule R7

Payment Provider claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification <no mitigation provided>

23 **Data Flow Charge card Is Potentially Interrupted** Not Started

Category Denial Of Service Priority High Generated by SDL rule D4

An external agent interrupts data flowing across a trust boundary in either direction.

Justification <no mitigation provided>

Interaction: Payment result

Payment Provider → Shop Web App · crosses **Shop backend**

24 **Cross Site Scripting** — Not Started

Category Tampering Priority High Generated by SDL rule T13.1

The web server 'Shop Web App' could be a subject to a cross-site scripting attack because it does not sanitize untrusted input.

Justification <no mitigation provided>

25 **Potential Data Repudiation by Shop Web App** — Not Started

Category Repudiation Priority High Generated by SDL rule R6

Shop Web App claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification <no mitigation provided>

26 **Potential Process Crash or Stop for Shop Web App** — Not Started

Category Denial Of Service Priority High Generated by SDL rule D3

Shop Web App crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification <no mitigation provided>

27 **Data Flow Payment result Is Potentially Interrupted** — Not Started

Category Denial Of Service Priority High Generated by SDL rule D4

An external agent interrupts data flowing across a trust boundary in either direction.

Justification <no mitigation provided>

28 **Elevation Using Impersonation** — Not Started

Category Elevation Of Privilege Priority High Generated by SDL rule E5

Shop Web App may be able to impersonate the context of Payment Provider in order to gain additional privilege.

Justification <no mitigation provided>

29 **Shop Web App May be Subject to Elevation of Privilege Using Remote Code Execution** — Not Started

Category Elevation Of Privilege Priority High Generated by SDL rule E6

Payment Provider may be able to remotely execute code for Shop Web App.

Justification <no mitigation provided>

30 **Elevation by Changing the Execution Flow in Shop Web App** — Not Started

Category Elevation Of Privilege Priority High Generated by SDL rule E7

An attacker may pass data into Shop Web App in order to change the flow of program execution within Shop Web App to the attacker's choosing.

Justification <no mitigation provided>

31 **Cross Site Request Forgery** Not Started

Category Elevation Of Privilege Priority High

Generated by SDL rule 8404dcf5-bdd8-4902-abc2-3b6c967b0261

Cross-site request forgery (CSRF or XSRF) is a type of attack in which an attacker forces a user's browser to make a forged request to a vulnerable site by exploiting an existing trust relationship between the browser and the vulnerable web site. In a simple scenario, a user is logged in to web site A using a cookie as a credential. The other browses to web site B. Web site B returns a page with a hidden form that posts to web site A. Since the browser will carry the user's cookie to web site A, web site B now can take any action on web site A, for example, adding an admin to an account. The attack can be used to exploit any requests that the browser automatically authenticates, e.g. by session cookie, integrated authentication, IP whitelisting. The attack can be carried out in many ways such as by luring the victim to a site under control of the attacker, getting the user to click a link in a phishing email, or hacking a reputable web site that the victim will visit. The issue can only be resolved on the server side by requiring that all authenticated state-changing requests include an additional piece of secret payload (canary or CSRF token) which is known only to the legitimate web site and the browser and which is protected in transit through SSL/TLS. See the Forgery Protection property on the flow stencil for a list of mitigations.

Justification <no mitigation provided>

Interaction: Audit events

Shop Web App → Audit Log

32 **Spoofing of Destination Data Store Audit Log** Not Started

Category Spoofing Priority High Generated by SDL rule S7.1

Audit Log may be spoofed by an attacker and this may lead to data being written to the attacker's target instead of Audit Log. Consider using a standard authentication mechanism to identify the destination data store.

Justification <no mitigation provided>

33 **Risks from Logging** Not Started

Category Tampering Priority High Generated by SDL rule T5

Log readers can come under attack via log files. Consider ways to canonicalize data in all logs. Implement a single reader for the logs, if possible, in order to reduce attack surface area. Be sure to understand and document log file elements which come from untrusted sources.

Justification <no mitigation provided>

34 **Lower Trusted Subject Updates Logs** Not Started

Category Repudiation Priority High Generated by SDL rule R1

If you have trust levels, is anyone other outside of the highest trust level allowed to log? Letting everyone write to your logs can lead to repudiation problems. Only allow trusted code to log.

Justification <no mitigation provided>

35 **Data Logs from an Unknown Source** Not Started

Category Repudiation Priority High Generated by SDL rule R2

Do you accept logs from unknown or weakly authenticated users or systems? Identify and authenticate the source of the logs before accepting them.

Justification <no mitigation provided>

36 **Insufficient Auditing** Not Started

Category Repudiation Priority High Generated by SDL rule R3

Does the log capture enough data to understand what happened in the past? Do your logs capture enough data to understand an incident after the fact? Is such capture lightweight enough to be left on all the time? Do you have enough data to deal with repudiation claims? Make sure you log sufficient and appropriate data to handle a repudiation claims. You might want to talk to an audit expert as well as a privacy expert about your choice of data.

Justification <no mitigation provided>

37 **Potential Weak Protections for Audit Data** Not Started

Category Repudiation Priority High Generated by SDL rule R4

Consider what happens when the audit mechanism comes under attack, including attempts to destroy the logs, or attack log analysis programs. Ensure access to the log is through a reference monitor, which controls read and write separately. Document what filters, if any, readers can rely on, or writers should expect

Justification <no mitigation provided>

38 **Potential Excessive Resource Consumption for Shop Web App or Audit Log** Not Started

Category Denial Of Service Priority High Generated by SDL rule D2

Does Shop Web App or Audit Log take explicit steps to control resource consumption? Resource consumption attacks can be hard to deal with, and there are times that it makes sense to let the OS do the job. Be careful that your resource requests don't deadlock, and that they do timeout.

Justification <no mitigation provided>

Created on 13/10/2026 17:37 by ThreatSketch 0.5.0 from TMT's SDL TM Knowledge Base (Core) template.